

- b. Analysis of the functionality, including security and resilience, of legacy systems and identification of gaps.
- c. Identification of necessary roles to support the EA function.

Objective 13: Management implements an IT infrastructure that achieves and promotes the objectives of confidentiality, integrity, and availability, and meets the entity's business objectives. (V, "Infrastructure")

1. Determine whether the entity's IT infrastructure implementation includes considerations for server and data redundancy and resilience of telecommunications lines.
2. *This examination procedure may be performed in coordination with the examination procedures in Objective 4 (ITAM).* Determine whether management has effective processes related to ITAM to track and monitor all hardware assets (whether or not they are connected to the network) to maintain an accurate and current record of the technology assets in its environment. As part of these processes, determine whether management does the following:
 - a. Identifies unauthorized technology assets and determines their disposition.
 - b. Evaluates how unauthorized devices gained access and whether any compromise occurred.
 - c. Updates the related policy or procedures or provides additional training.
3. *This examination procedure may be performed in coordination with the examination procedures in Objective 4 (ITAM).* Determine whether management documents and maintains a current inventory of network and telecommunications hardware and software and the standard network configuration for them. Additionally, determine whether management does the following:
 - a. Implements appropriate redundancy capabilities for the entity's telecommunications infrastructure.
 - b. Understands the limitations of the entity's third-party telecommunications providers' infrastructure.
 - c. Documents the network's baseline configuration, including processes to review and approve changes.
 - d. Regularly assesses and documents compliance with the entity's baseline configuration.
 - e. Appropriately controls networked devices by managing ports, protocols, and services and maps them to the devices on the technology asset inventory.
 - f. Installs the latest version of security-related updates on network devices, when appropriate.
 - g. Maintains standard images of the entity's servers and stores them securely. Uses clean (i.e., trusted) images to restore the server if a server needs to be rebuilt and documents, reviews, and approves deviations from the standard image.
 - h. Implements security and monitoring throughout the entity's network, analyzes incoming and outgoing data traffic, and alerts authorized personnel if anomalous activity is detected. Additionally, determine whether the following security and monitoring mitigation strategies are in place:

- Use of software tools to protect against and monitor internet-accessible services or open ports.
 - Implementation of firewalls and port filtering.
 - Deployment of IDS/IPS.
 - Use of internal tools to detect, identify, and prevent misuse by entity personnel.
 - i. Performs administrative activities from dedicated workstations.
 - j. Uses multi-factor authentication over encrypted network connections for administrators accessing and managing network devices.
 - k. Monitors telecommunications traffic and periodically reviews network devices.
 - l. Appropriately controls telecommunications equipment, including:
 - Physically securing it and restricting and monitoring access to it.
 - Following enterprise change control standards.
 - Following entity policies, standards, and procedures for identification, authorization, and authentication to access telecommunications systems.
 - m. Designs and builds telecommunications infrastructure components for resilience (e.g., implement route diversity), including selecting infrastructure components and telecommunications providers that help avoid a single point of failure.
 - n. Addresses voice communications risks through development and acquisition processes, and in written policies, standards, and procedures. If the entity uses VoIP for voice communications, determine whether management performs a comprehensive risk assessment to ensure confidentiality, integrity, and availability in voice communications.
 - o. Implements physical and logical controls in the VoIP environment, evaluates options for backup systems, and considers control solutions specific to VoIP, such as VoIP-ready firewalls.
 - p. Monitors incoming and internal data communications traffic for problems.
 - q. Implements redundant telecommunications services and establishes work-around procedures for situations where needed.
4. Evaluate whether management determines the types of software needed to implement the entity's strategic objectives and considers the software's scalability, interoperability, and portability. As part of its software infrastructure planning, determine whether management performs the following:
- a. Tracks and monitors the entity's software assets.
 - b. Maintains an accurate and current record of its software assets (e.g., with a software inventory).
 - c. Periodically reviews existing software.
5. *This examination procedure may be performed in coordination with related examination procedures in the "[Development and Acquisition](#)" booklet.* Determine whether management appropriately chooses software (e.g., to meet the entity's infrastructure and operational requirements) and considers whether to develop software internally or obtain it from a third party.

- a. With internally developed software, evaluate whether management is responsible for maintaining the software, and entity personnel have the resources and expertise to stay abreast of vulnerabilities and develop software updates and patches.
 - b. With externally developed software, evaluate whether management performed the following:
 - Determined whether COTS software meets the entity's needs and security requirements or if it will integrate with existing software and require further configuration.
 - Determined whether custom software was designed to integrate with the existing enterprise software, hardware, and data, and whether management considered issues related to obsolescence, patching, and availability of expertise.
 - c. Regardless of the type of externally developed software selected, determine whether management performed the following:
 - Approved the selected software's use and determined that it met the entity's infrastructure requirements and strategic objectives.
 - Allocated resources to support the software (e.g., financial and personnel) and determined that personnel have the expertise to maintain and patch the software.
6. *This examination procedure may be performed in coordination with related examination procedures in the "[Development and Acquisition](#)," "[Information Security](#)," and "[Outsourcing Technology Services](#)" booklets.* Determine whether management is aware of and implements risk mitigations for general risks (e.g., software vulnerabilities and unauthorized access) associated with software in the entity's infrastructure environment. With respect to specific software types, determine whether management does the following:
- a. For OS software:
 - Oversees and maintains the OS, including testing and installing patches when appropriate.
 - Restricts and monitors administrator access to the OS.
 - Limits the use of utility software.
 - b. For core processing software:
 - Restricts software based on job responsibility.
 - Monitors its use.
 - Selects core processing software with adequate capacity.
 - Chooses software that can support usage spikes, expected peak usage times, and future growth.
 - c. For productivity software:
 - Considers the use of it to enable personnel to perform their job functions.
 - Safeguards systems against security threats and employs IAM, configuration management, and log monitoring.
 - Employs mitigation strategies to address synchronization issues.
 - d. For enterprise software:
 - Considers how enterprise software integrates in the entity's infrastructure environment.
 - Limits access and editing capabilities.
 - Monitors user activity.

- e. For security software:
 - Uses security software that is current, deployed effectively, and designed to keep up with the evolution of malicious code.
 - Restricts administrative access to this type of software.
- f. For system auditing software:
 - Uses system auditing software to augment audit personnel.
 - Uses the software to assist in the identification of gaps in infrastructure security and resilience.
 - Documents software for system audit use and defines its purpose.
- g. For open source software:
 - Identifies security issues with its use.
 - Implements security controls and procedures to mitigate risks, including the following:
 - Defining acceptable use (or restriction) guidelines and documenting a process for modifying and reviewing the code.
 - Restricting access to unapproved shareware sites.
 - Using tools to help discover unapproved open source software.
 - Identifying the type and version of open source software in use, where it is used within the entity, and its purpose.
 - Implementing version and patch control guidelines for open source software in use.
 - Monitoring for vulnerabilities of the open source software employed by the entity.
 - Evaluates implications of open source components in third-party software and addresses their use in contract provisions.
 - Evaluates open source software components during software due diligence.
- h. For mainframe security software:
 - Implements access controls (e.g., role-based access, segregation of duties, and multi-factor authentication).
 - Uses security controls.
 - Encrypts sensitive information.
 - Enables activity log settings (e.g., user access, failed login attempts, and security setting changes).
 - Implements real-time monitoring and alerting.
 - Performs timely patch management.
 - Verifies mainframe security auditing (e.g., regular review and validation of security controls, privileges, roles, and access profiles).
 - Independently monitors privileged accounts (e.g., system and security administrators).
 - Maintains appropriate mainframe security expertise.
- i. For APIs:
 - Assesses and implements security needs for APIs.
 - Addresses authorization, authentication, and encryption.
 - Implements API security tools and gateways with controls for requests and responses.
 - Performs sensitive data filtering.

- Places restrictions on size and number of resources requested.
 - Identifies API request checkpoints for information leaving the network.
 - Performs appropriate API logging and monitoring.
 - Implements other security controls (e.g., secure IPs, password hashing, restriction of secret information, authorization protocols, validation mechanisms, time stamping, rate limiting, API traffic monitoring, and API gateway configuration) as appropriate for internal APIs.
 - Implements adequate security and restrictions over the use of public APIs to protect sensitive customer and entity data and performs appropriate testing to verify the adequacy of security controls over a third party's APIs.
 - As part of its customer awareness program, makes security awareness information available to its customers using unaffiliated third-party API services. Determine whether the information addresses protections available and not available when the customer allows access to its data.
7. *This examination procedure may be performed in coordination with related examination procedures in the “[Outsourcing Technology Services](#)” booklet.* Determine whether management performs the following, depending on the type of software hosting involved:
- a. For internally hosted software, determine whether management:
 - Identifies personnel (e.g., internal or third-party) with relevant skills and expertise.
 - Allocates resources for necessary training to maintain knowledge.
 - Follows a system development life cycle that incorporates security if the entity develops software in-house.
 - b. For externally hosted software, determine whether management:
 - Has contract provisions addressing the notification of infrastructure changes and the third party's use of any subcontractors.
 - c. For hybrid hosted software arrangements, determine whether management:
 - Performs an adequate risk assessment to prepare for a potential service interruption.
8. *This examination procedure may be performed in coordination with related examination procedures in the “[Business Continuity Management](#)” booklet.* Determine whether management developed, documented, and implemented environmental control policies, standards, and procedures to safeguard facilities, technology, data, and people. Specifically, determine whether management has effective environmental controls to identify and mitigate risks from infrastructure and operational issues. Evaluate whether remotely available environmental controls (including IoT devices used for environmental monitoring), whether by a third-party service provider or not, have appropriate access controls, monitoring of remote access activity, and regular review of privileges. Additionally, determine whether third-party service provider access for maintenance and administrative purposes are appropriately controlled.
9. Review the effectiveness of management's mitigation of the risks associated with the following:
- a. HVAC controls, including:

- Maintaining appropriate temperature and humidity levels.
- Monitoring HVAC.
- Implementing automated monitoring and providing an alarm or notification of significant temperature changes.
- Considering the entity's need for redundant HVAC equipment components.
- b. Smoke and fire mitigation strategies, including:
 - Appropriate smoke and fire detection systems.
 - Smoke and fire detectors in appropriate locations.
 - Devices and systems for smoke detection, fire suppression, and fire detection supported by an independent energy source.
 - Inspections of facilities for potential fire hazards and resolution of identified deficiencies.
 - Training.
 - Evaluation of all systems for their advantages and disadvantages.
 - Knowledge of potential risks of fire suppression systems.
 - Contract provisions for smoke and fire detection in third-party hosted infrastructure situations.
- c. Water detection controls, including:
 - Use of water detectors in raised floors or in ceilings to alert management.
 - Consideration of automated mechanisms to detect the presence of water and provide alerts.
- d. Power issues mitigation, including:
 - Steps to protect computing equipment from inconsistent and dirty power sources.
 - Consideration of long-term alternate power supply to provide operational capability during extended power outages.
 - Appropriate power configurations based on the entity's power needs.
 - Use of independent electrical feeds drawing from separate power grids and automatic fail-over to a live power source, where multiple feeds or backup power generators are used.
 - Evaluation and mitigation of the risk from one grid or one provider in other ways (e.g., using generator(s) or batteries).
 - Methods to monitor, condition, or stabilize the electricity source voltage and minimize effects of power fluctuations.
 - Use of alternative power sources independent of local power grids.
 - Processes to power down IT systems in an orderly manner to maintain critical information for later recovery, in cases where power cannot be maintained (e.g., during emergencies).
 - Activation of automated emergency lighting of critical infrastructure, evacuation routes, and emergency exits.
- e. Physical access controls, including:
 - List of approved individuals with authorized physical access to the IT infrastructure facilities.
 - Validation of access authorizations before granting access to restricted spaces.
 - Use of credentials for entity personnel and visitor badges for visitors.
 - Logs of individuals that access restricted spaces.
 - Use of physical intrusion alarms and surveillance equipment.

- Visitor escorts and visitor activity monitoring.
- Security over combinations, keys, and other physical access devices; processes to change combinations or keys as needed; and removal of electronic user credentials, when appropriate.
- Inventory of physical access devices at regular intervals.
- Regular reviews of access lists and removal of unnecessary access.
- Alternative physical access processes if electronic controls fail.

The next four objectives (14–17) are related to [section VI, “Operations.”](#) Examination objectives for this section were divided into four sub-sections: “Operational Controls,” “Operational Processes,” “Service and Support Processes,” and “Ongoing Monitoring and Evaluation Processes,” following the layout in the booklet.

Objective 14: Management develops and implements operational controls to safeguard the entity’s operational environment. (VI.A, [“Operational Controls”](#))

The examination procedures in this objective may be performed in coordination with related examination procedures in the [“Information Security”](#) booklet.

1. With respect to operating centers, describe the entity’s operating center type and key responsibilities and determine whether functions such as security and network management are addressed. Evaluate the appropriateness of the entity’s processes and controls, such as the following:
 - a. Responsibility for the physical location as well as the on-premise equipment and systems in entity-owned versus outsourced operating centers.
 - b. Contract(s) specifying equipment ownership and responsibility, if management of the operating center is outsourced.
 - c. Operating centers located in areas less prone to environmental threats.
 - d. Appropriate security and environmental controls within the entity’s infrastructure, including:
 - Use of smoke, water, and power detection and mitigation devices and systems, as well as fire suppression systems.
 - Use of security zones limiting access within restricted spaces.
 - Implementation of physical security controls.
 - Use of devices to restrict and log access to the site.
 - Procedures for appropriate site maintenance.
 - e. Responsibilities for implementing security and environmental controls.
 - f. Operating center responsibilities, including:
 - Training staff to operate and maintain the entity’s equipment and systems.
 - Deploying appropriate connectivity.
 - Managing incidents and events.
2. Determine whether management defines the entity’s authorization boundary(ies) and implements appropriate security controls according to the contents of the authorization boundary, including controls over the following:

- a. Internal and external communication systems within and across the entity's authorization boundary(ies).
 - b. The connection between the entity and its third parties.
 - c. Physical, logical, and environmental controls.
 - d. Perimeter protection devices.
 - e. People and processes supporting the entity's missions and business functions.
3. Determine whether management implements appropriate IAM processes and does the following:
 - a. Appropriately provides access to the entity's resources.
 - b. Considers enhanced authentication, especially for privileged access.
 - c. Considers its implementation of cloud services and addresses the unique access control requirements for cloud environments, as appropriate.
 - d. Maintains a policy and implements related standards and procedures to identify users and restrict their access.
4. Determine whether management has processes for employee recruitment, hiring, and placement and provides for thorough applicant screening and background checks at the time of employment. Review the following and evaluate their effectiveness:
 - a. Performance of background checks at an appropriate frequency.
 - b. Definition of duties, responsibilities, expectations, and accountability.
 - c. Implementation of dual control and segregation of duties.
 - d. Independently monitoring activities.
 - e. Implementation of rotation of duties.
 - f. Reviewing and monitoring of activities performed during rotation of duties.

Objective 15: Management implements effective IT operational processes to reduce the number of potential operational failures and minimize the impact of issues that occur. (VI.B, "IT Operational Processes")

The examination procedures in this objective may be performed in coordination with related examination procedures in the "Information Security" and "Outsourcing Technology Services" booklets.

1. Determine whether management has assigned responsibility for the performance of maintenance on the entity's equipment. Evaluate whether the following is effective:
 - a. Routine maintenance by data center employees is performed according to manufacturers' recommendations.
 - b. Preventive maintenance follows a predetermined schedule.
 - c. Operations employees document both internal routine (if any) and externally provided maintenance in logs and other records.
 - d. Management reviews maintenance records.

- e. For equipment owned or leased from a third party, management obtains a separate agreement to manage maintenance. The agreement includes:
 - Preventive maintenance to be performed.
 - Provisions for repair services.
 - Schedule for maintenance and time frame for repair.
 - f. Management provides time and resources for scheduled preventive maintenance, which includes:
 - Limiting the service representative's access to the minimum necessary.
 - Having at least one computer operator present when the service representative is on site.
 - Reviewing system activity logs to monitor access to programs or data during maintenance.
 - Following established security procedures to ensure representatives have only the necessary access at predetermined times to perform specific tasks.
 - g. If there is an arrangement with a contractor to manage the entity's preventive maintenance and repair services, the contract or agreement guarantees timely performance of maintenance.
 - h. If computer maintenance is performed online, the online maintenance schedule is available to prevent interference with normal operations and processing.
 - i. Maintain a log of all hardware or software problems and downtime encountered between maintenance sessions.
2. Evaluate whether management has policies, standards, and procedures for configuration management and defines and implements appropriate configuration settings. In addition, verify whether management does the following:
 - a. Appropriately defines and applies configuration settings on IT products at the entity.
 - b. Ensures that systems and software used to support entity operations have appropriate configuration management capabilities, including configuration of audit log settings, and enforces configuration management.
 3. Determine whether management establishes procedures to stay abreast of system vulnerabilities and software vendor patches, tests patches in a segregated environment, and installs them when appropriate. Additionally, determine the effectiveness of the following:
 - a. Management implements a vulnerability management program that identifies systems and software vulnerabilities, prioritizes the vulnerabilities and the affected systems in order of risk, and performs timely remediation according to the risk of the vulnerability. The vulnerability management program includes the following:
 - Systems and software operating in the cloud for which the entity is responsible as well as those managed by the entity on its premises.
 - Processes to monitor industry third parties (e.g., US-CERT, NIST, and FS-ISAC) that report vulnerability exposures and address any relevant exposures within the entity's systems and software.
 - Processes to periodically assess systems and software for vulnerabilities using scanners with current vulnerability lists.

- Vulnerability scans of all systems and software in the entity’s hardware, software, and telecommunications inventories.
 - Appropriate controls over vulnerability scanning tools, including controls to protect against unauthorized use or access to sensitive information.
 - Use of dedicated accounts for authenticated vulnerability scans.
 - Methods to track and report on nonconformance to entity policies and the timeliness and remediation progress of all identified vulnerabilities, including those related to security procedures, physical layout, or internal controls.
 - b. Management implements a patch management program that includes documentation of any patch installations. The patch management program includes the following:
 - Processes to document patch installations as part of the entity’s change management procedures.
 - Systems and software for automated patch management or other demonstrated effectiveness in keeping up with patch identification, testing, and installation.
 - Records of the system and software versions in place and regular monitoring of online and industry resources for information on product enhancements, security or other issues, patches, or upgrades.
 - Communication and integration with the entity’s third-party service providers to align the entity’s patch management program with those of the third-party service providers.
4. *This examination procedure may be coordinated with the examination procedures in the “[Business Continuity Management](#)” and “[Information Security](#)” booklets.* Determine whether management implements backup methods, including replication, based on the risk and criticality of the systems and data.
- a. As part of its backup and replication processes, determine whether management maintains the following:
 - Policies, standards, and procedures.
 - Inventories of backup media, storage location, and access controls for the media or physical location.
 - Documented periodic physical reviews to confirm that all relevant backup material is available.
 - Procedures to verify adherence to backup schedules.
 - Processes to regularly test backup copies for readability.
 - Capability to restore operations to a previous trusted state.
 - Backups of configurations and data off-site and on a separate system or media.
 - VM versioning, replication, and life cycle policies for backup processes.
 - Data encryption and access controls to protect backup or replicated data from unauthorized access, destruction, or corruption.
 - Proper sanitization and disposal of data when it is no longer needed to prevent the disclosure of information to unauthorized users.
 - b. When using third-party service providers for backup and replication, determine whether management validates that the third-party service provider performs the processes above.